2026 深圳国际金融科技大赛 · 人工智能赛道（AI Banking）

财小全 · AI 财务中枢

安全自评报告：权限分级实现 · 资金安全 · 已知风险清单

评估对象：财小全.html

评估方式：源码审计 + 威胁建模 + 定向用例 + 数据流分析

自评结论：原型边界内无高危未缓解项；上线前须完成后端化改造

文档编号　CXQ-SEC-2026-001　　版本　V1.1

编制　金财智研团队　　日期　2026 年 10 月 28 日

文档信息

项目	内容
文档名称	《财小全 · AI 财务中枢 安全自评报告》
文档编号 / 版本	CXQ-SEC-2026-001 / V1.1
评估对象	财小全-比赛修正版_修复版.html（单文件，376.8 KB）及导入导出功能
评估范围	权限分级、资金与交易安全、数据隐私、内容安全、审计追溯
评估方法	源码逐函数审计、STRIDE 威胁建模、定向逻辑用例、数据流分析、配置核查
风险统计	共识别 15 项：高 0 项、中高 2 项、中 8 项、低 5 项
报告性质	项目团队自评，非第三方安全审计；不构成任何监管合规认证
配套材料	01 技术文档；03 源代码与部署材料（含验收清单与审查记录）

修订记录

版本	日期	修订内容
V1.0	2026-10-26	首次成稿：权限实现、资金安全、隐私、风险清单与整改计划
V1.1	2026-10-28	按修复版源码重评：补入 CSV 导出公式注入、JSON 全局覆盖、账号会话隔离、存储结构容错、删除二次确认重验；风险清单按现状重新分级

阅读说明

本报告遵循「先说明边界、再说明控制、最后说清残余风险」的顺序。凡未在原型中真实实现的控制，一律标注为「方案层设计 / 待落地」，不与已实现的控制混写。凡未完成的验证，明确写「未完成」，不写成通过。

一、 评估范围与方法

1.1 边界

资产 / 环节	是否在范围	说明
单文件应用（路由、测算、渲染）	在范围内	逐函数审计，含权限、资金、反诈、审计模块

资产 / 环节	是否在范围	说明
本机浏览器存储（12 个键）	在范围内	含数据归属、导出导入、结构容错；密钥另存会话级
模型调用链路	在范围内	含上下文装配、脱敏、错误处理与降级
静态托管与转发配置	部分在范围	仅评估配置建议，不评估云平台自身安全
真实银行核心、支付清算、持牌代销	不在范围	原型不接入，也不具备接入能力
第三方模型服务商内部	不在范围	仅评估传输与数据暴露面
服务端数据库	不在范围	当前版本未部署任何数据库服务

1.2 评估依据

类别	依据	使用方式
金融数据	《金融数据安全 数据安全分级指南》JR/T 0197—2020	参照分级思路对数据项定级，不等同监管认定
个人金融信息	《个人金融信息保护技术规范》JR/T 0171—2020	对照最小必要、加密传输、访问控制
个人信息	《中华人民共和国个人信息保护法》	对照告知同意、目的限定、可删除
数据安全	《中华人民共和国数据安全法》	对照分类分级与安全管理制度
网络安全	《中华人民共和国网络安全法》	对照等级保护思路下的基本防护
赛事要求	大赛 04 安全自评报告提交要求	权限分级实现说明 + 已知风险清单为必备章节

1.3 方法

- **源码审计**：逐函数检查取数、鉴权、写操作、日志四类路径，确认每条路径的失败行为。
- **威胁建模**：按 STRIDE 六类威胁梳理攻击面，逐项对应控制。
- **定向用例**：以自然语言输入驱动路由，断言返回卡片类型、文案关键词与审计记录。
- **数据流分析**：追踪每个数据项从产生、存储、展示到出网的完整路径。
- **配置核查**：检查密钥存放、导出内容、脱敏范围与备份行为。

1.4 STRIDE 威胁建模

威胁	本项目场景	现有控制	残余风险

威胁	本项目场景	现有控制	残余风险
S 身份伪造	在本机切换账号冒充他人	切换需显式选择模式与账号，身份写入审计；无自动登录态	中：前端无强身份认证
T 数据篡改	直接修改 localStorage 的流水与权限	关键结论本地重算，不缓存结论；非数组结构回退空数组	中：无签名校验
R 抵赖	否认曾发起转账或授权	审计链逐条留痕，断链可定位	中：本地日志可被清除
I 信息泄露	模型请求携带账本上下文	卡号/手机号/身份证掩码；上下文仅当前账号	中高：脱敏非匿名化，服务商侧不可控
D 拒绝服务	存储配额不足导致写入失败	写入失败明确提示「当前会话 / 已保存」区别	低
E 权限提升	子账号读取薪酬与明细	权限码门控 + 敏感字段拦截 + 技能锁定	低：前端可被改代码绕过

二、 数据流与出网边界

数据只走两条路，分界点是「是否配置了模型密钥」。

输入（键盘 / CSV / 粘贴）
→ 本地解析与校验（`cxqParseCsv / validIsoDate / applyImportJson`）
→ `localStorage`（`cxf-txns` 等 12 键）
→ 本地计算（台账 / 卡片 / 看板 / 审计链） ← 不出网

自由提问（长句）
→ `agentIdentity + agentDataContext` 装配
→ `cxqMaskSensitive` 掩码（卡号 / 手机 / 身份证）
→ `HTTPS POST {base}/chat/completions` ← 唯一出网点
→ `SSE` 逐块渲染，不落盘原始响应

数据项	本地存储	是否出网	控制
逐笔流水（含商户）	cxf-txns	出网：按上下文摘要（最近 20 笔）	仅当前账号；商户名不脱敏
账本汇总（三个月收支）	派生数据	出网：汇总行	仅当前模式与账号
卡号 / 手机 / 身份证	页面模拟数据	掩码后出网	前 4 后 4 / 前 3 后 4 / 前 6 后 4
模型密钥	sessionStorage	仅作为 Authorization 头发往所配服务商	不进 localStorage、不进导出

数据项	本地存储	是否出网	控制
审计记录	cxf-audit	不出网（导出为用户主动下载）	本地文件
备份 JSON	用户主动导出	不出网，除非用户自行上传	导出内容不含密钥

三、 权限分级实现说明

3.1 权限码与账号

权限模型由 3 个权限码、7 个演示账号、18 项技能与三级可见粒度组成。判定函数 hasPerm 的语义是「当前账号的权限集合是否包含所需权限」，默认集合为只读，主账号集合为三者全含。

7 个演示账号 × 权限码 × 可见粒度

账号键（模式:账号）	角色	权限码	可见粒度	账本
enterprise:operator	经营者	读写主	明细	自有
enterprise:investor	投资人	只读	摘要	自有 + 挂载
personal:self	本人	读写主	明细	自有
personal:advisor	财税顾问	只读	结论	自有 + 挂载
family:keeper	管钱者	读写主	明细	自有
family:member	消费成员	只读	摘要	自有 + 挂载
family:elder	长辈 · 关怀	只读	结论	自有 + 挂载

权限码：read 只读 / write 需写权限 / main 需主账号；子账号默认仅 read

图 3　7 个账号 × 权限码 × 可见粒度

权限码	含义	授予账号
read	只读：可看本账号可见范围内的内容	全部 7 个账号
write	可写：可发起记账、定时、分摊、导出等写操作	operator、self、keeper
main	主账号：可审批与收回子账号授权	operator、self、keeper

3.2 三级可见粒度

粒度	内容	适用
detail（明细）	逐笔流水、凭证号、薪酬、卡号	主账号本人
summary（摘要）	汇总金额、环比、结论摘要，不含逐笔与卡号	投资人、消费成员

粒度	内容	适用
conclusion（结论）	测算结论与缺口金额，不含明细	财税顾问、长辈

3.3 拦截点与失败行为

拦截点	实现方式	失败行为
技能门控	launchSkill 先查 hasPerm(skill.perm)	锁定态 + 提示申请 + 写「技能被拒绝」审计
敏感字段问询	子账号 + 工资/薪酬/员工/明细流水/卡号/逐笔	拒绝卡，说明授权范围，建议切换主账号
资金动作发起	转账/定时/分摊前校验账号类型	子账号一律转越权提示，不生成单据
定时任务读取	findSched 同时校验 id 与 owner	非本人任务不可见、不可改、不可删
分摊单读取	findBill 校验单据模式与成员	跨模式、跨成员单据不可见
数据源守卫	myTxns / ledger / sharedLedger 以 acctKey 取数	其他模式与其他账号数据不进入上下文
会话与草稿	setAccount 先存草稿，再载入目标账号；无会话则置空	不继承上一账号的会话标识与草稿

3.4 权限分级的边界

这套分级是「前端演示隔离」：它保证同一份演示数据在七个身份之间不串号、不越界，也让评审能直观看到最小授权如何工作。但它不是服务器授权——任何人拿到 HTML 都可以修改脚本或本地存储。真正的权限控制必须放在后端，这一点在第九章列为 R01。

四、 资金与交易安全

4.1 转账不是执行，是生成单据

转账链路分四步：解析金额（支持阿拉伯数字、万千单位与中文数字）、解析收款人、解析备注、生成待确认单并落盘为草稿。金额缺失时不猜测、不默认，直接返回「信息不全」并给出示例句式。用户确认后只生成一条待办指令，并提示到银行 App 自行完成，全程不经手资金。

风险等级	触发条件	处置
低	小额且收款人在白名单	一句提醒
中	首次收款人或金额接近上限	弹二次确认卡

风险等级	触发条件	处置
高	陌生账户或超过单笔上限	要求实名核对，仍不执行
拦截	命中电诈话术或注入	直接拦死，写风险审计

方案层预留三个风控参数：收款人白名单 payee_whitelist、单笔确认上限 single_confirm_limit（默认 10,000）、日累计上限 daily_out_limit。当前为演示参数，未接入真实通道。

4.2 写操作确认

cxqDetectWrite 覆盖转账、挂失、冻结卡、申购、赎回、退订、取消订阅、购买理财等动作，命中后一律进入 cxqProposeWrite → 二次确认，不自动执行。删除流水同样二次确认，且在确认回调里重新校验索引、账号归属、日期、商户、金额与类型——若记录已变化则取消删除并要求刷新列表，避免弹窗期间数据变化导致误删。

4.3 不做的三件事

- **不推销**：不推荐具体理财产品，不出现收益率与购买入口；只给「留多少、放哪里」的方向性比例。
- **不代客**：不执行转账、不开通账户、不代客操作；所有资金动作止于待办。
- **不承诺**：不承诺额度、利率与通过率；信贷卡片只摆指标与结论。

五、 数据隐私保护

5.1 存储与删除

流水、任务、分摊单、贷款方案、草稿、审计记录全部落在本机 localStorage 的 12 个键内，不上传、不同步；清除浏览器数据即彻底清除。模型密钥单独放 sessionStorage，关闭标签页即失效；历史版本的长期存储密钥会在读取时迁移并清除明文。

5.2 最小必要与脱敏

上下文只装配当前账号可见的数据；子账号只附结论层汇总。发往模型的文本统一过 cxqMaskSensitive：卡号保留前 4 后 4、手机号保留前 3 后 4、身份证保留前 6 后 4。商户名与金额不脱敏——这是让模型能回答「哪笔账有问题」的必要信息，也构成一项需要披露的残余风险。

5.3 导出与备份

账单导出经 cxqCsvCell：双引号转义，并以 = + - @ 开头的文本前置单引号，防止电子表格公式注入；金额列保持数值可计算。备份 JSON 不含密钥；恢复属于本机数据全局替换，确认框明确提示会覆盖流水、定时任务与分摊单，恢复后逐集合检查保存状态，部分失败时提示「已恢复到当前会话，但部分本地保存失败」。

六、 内容安全与合规

6.1 提示词注入

cxqDetectInjection 位于全部路由最前，命中即短路，不进入任何业务流程。覆盖「忽略之前/以上/所有指令」「ignore previous」「忘记你的指令/身份」「你现在不再/是」「从现在开始忽略」「绕过 / bypass」「扮演一个」等表达。产出为固定文案的阻断卡，不生成任何可点击的资金按钮，同时写入风险审计。

6.2 七类电诈话术

类型	触发特征	处置
冒充客服	自称银行/电商/平台客服，且出现提额、注销账号、账户异常或冻结	拦截 + 96110
安全账户	出现安全账户/指定账户/监管账户，且伴随转、汇、打款、存	拦截 + 96110
涉案恐吓	涉嫌/涉案 + 洗钱、诈骗、违法、犯罪	拦截 + 96110
理赔 / 社保异常	快递理赔、包裹理赔、社保卡或医保卡异常，且要求配合、核实、解冻、加微信、点链接	拦截 + 96110
要求保密	不要/别/不能 + 告诉/联系 + 家人、父母、警察、银行、柜员	拦截 + 96110
屏幕共享	屏幕共享/远程控制/远程协助，且伴随转、汇、验证码、账户	拦截 + 96110
偷偷转账	偷偷 + 转/汇/打款/打钱	拦截 + 96110

6.3 合规拒答

理财推荐、资产盘点类请求命中合规红线时，返回固定拒答卡并给出替代路径（资金安排、缺口测算），不输出产品名、收益率与购买渠道。可疑交易扫描的文案明确写了「命中的是演示启发式规则，不等于确认诈骗」「未命中当前规则不代表交易一定安全」。

6.4 内容边界

税额卡片固定标注「需核验纳税人身份、业务类型、销售额口径及优惠适用条件，不可直接替代申报结果」；健康分、保障缺口、贷款模拟均标注为演示参数或简化模型；长辈视图不出现分数术语与资金入口。

七、 审计与可追溯

7.1 记录结构

字段	含义
t	时间戳（本地格式化）
action	动作名，如「启用技能」「风险·钓鱼话术拦截」「导出账单 CSV」
obj	对象与被操作内容的摘要
prev	前一条记录的哈希，形成链
h	本条哈希 = FNV-1a 32 位(prev + 时间 + 动作 + 对象)

7.2 完整性校验

verifyAuditChain() 从链头逐条重算：prev 不匹配或哈希不匹配即返回断点位置（第几条 / 共几条）。初始化时恢复链头并校验历史链，刷新页面后不会出现「链头丢失但记录继续写」的错位。导出审计报告时附链状态，便于评审现场核对。

7.3 能力边界

cxqHash 是 32 位非密码学哈希，浏览器本地日志可被用户清除或修改。它适合演示中的链式留痕与断链定位，不适合宣传为银行级、不可篡改或法律级审计。生产级实现需要服务端签名、权限控制、可信时间源与独立日志存储——本版按演示定位未重构，列为 R04。

八、 测试与验证

检查项	方法	结果
内联 JavaScript 语法	new Function 解析（不执行）	通过
静态 id 唯一性	全文比对	93 个，重复 0
流水归月定向用例	覆盖有效月份、跨年份、窗口外、无日期、无年份、非法月份	通过
CSV 导出转义	代码审查 + 语法检查	已实现；Excel/WPS 显示差异未实测
健康分自检	checkCalcs()	通过
浏览器端到端	Playwright / Chromium	未完成（环境策略阻断），不计为通过
恶意篡改审计链	构造断链场景	未做

本报告不把静态检查通过写成全部实测通过。随包的《测试用例清单》覆盖账号切换、导入导出、备份恢复、贷款方案、审计刷新与移动端布局，供人工逐项记录。

九、 已知风险清单

编号	风险	等级	现有控制	残余风险 / 整改方向
R01	前端身份可切换，无强认证	中高	显式选择账号、身份写审计、最小授权门控	改代码即可绕过；需后端鉴权（P1）
R02	模型请求携带账本上下文，脱敏非匿名化	中高	仅当前账号、卡号/手机/身份证掩码	商户与金额明文；取决于所选服务商（P1）
R03	localStorage 可被本机清除或篡改	中	关键结论本地重算；非数组结构回退	无签名与备份校验；增加导出提醒（P2）
R04	审计链为 32 位非密码学哈希	中	链式 prev + 哈希校验、断链定位	本地可改写；服务端签名（P1）
R05	JSON 恢复是全局覆盖	中	确认框提示覆盖范围、恢复前建议备份	可能覆盖其他账号流水；账号级合并（P2）
R06	提前还款为简化等比模型	中	展示假设与非正式方案说明	不含合同利息/违约金（P2）

编号	风险	等级	现有控制	残余风险 / 整改方向
R07	税额为条件化测算	中	卡片注明依据、假设与申报边界	口径变化需重新核验（P2）
R08	健康分、部分基线与税贷模块为预设值	中	页面与文档多处披露「独立演示参数」	导入流水不联动重算（P2）
R09	反诈与可疑交易为启发式规则	中	文案说明可能误报漏报、不给确诊结论	非模型风控（P2）
R10	一键演示回滚快照仅在内存	低	提示演示后同页退出或先备份	刷新后无法自动回滚（P3）
R11	CSV 解析不支持字段内含换行	低	逐行解析 + 引号转义 + 失败提示	复杂文件可能被拆坏（P3）
R12	CSV 日期要求完整年月日	低	缺年份的日期跳过并计数	9/12 类写法不被接收（P3）
R13	Excel/WPS 对前置单引号的显示差异未实测	低	导出统一转义策略	需在目标办公软件回归（P3）
R14	移动端布局与弹窗未完整回归	低	响应式断点与横向滚动处理	需真机验收（P3）
R15	浏览器端到端未实测	低	已提供验收清单	环境阻断，需人工补测（P3）

风险统计：高 0 项、中高 2 项、中 8 项、低 5 项。两项中高均属架构性限制（前端身份、模型出网），不是代码缺陷，需要后端化才能根治，因此在原型阶段以「明确披露 + 缩小暴露面」处理。

十、 整改计划

优先级	事项	归属	验收标准
P0（上线前必做）	后端鉴权与服务端数据权限；审计改服务端签名 + 可信时间源	架构	越权与篡改在前端无法绕过
P0	模型链路服务端代理，密钥不下发浏览器；上下文最小化	架构	浏览器侧无可用密钥，出网内容可审计
P1	账号级备份合并、恢复前校验与回滚快照	功能	恢复失败时原数据完整保留
P1	浏览器端到端回归 + 移动端真机验收	测试	验收清单全部有结论
P2	税务口径与贷款模型接入正式参数源	算法	结论附口径版本与假设
P3	CSV 解析升级为成熟库；Excel/WPS 兼容矩阵	工程	复杂 CSV 与主流办公软件通过

十一、 自评结论

在「单文件演示原型」这一边界内，本版未发现高危未缓解项：权限分级、输入安全、写操作确认、审计留痕均已实现且有明确的失败行为；资金环节全部止于待办，不触达真实账户。两项中高风险的共同根因是「前端即边界」——身份与数据都放在浏览器里，这既是原型的取舍，也是上线前必须改造的部分。

本报告不声称通过任何认证或达到监管合规要求，也不把未完成的浏览器验证写作通过。剩余验证缺口与产品级限制已在第九、十章逐项列出，评审可据此判断原型的能力边界。

附录 A 安全检查表

检查项	结论
权限码与账号集合是否一一对应	是（3 码 / 7 账号）
越权路径是否有明确失败行为	是（拒绝卡 + 审计）
写操作是否都不直达执行	是（二次确认 / 待办）
是否存在真实资金通道	否
密钥是否进长期存储	否（sessionStorage）
导出是否防公式注入	是（cxqCsvCell）
审计是否可校验	是（链式哈希，非签名）
是否有未披露的预设数据	否（页面与文档均标注）

附录 B 与大赛提交要求对照

提交要求	本报告对应章节
权限分级实现说明	第三章（权限码、可见粒度、拦截点、边界）
已知风险清单	第九章（15 项，含等级与控制）
评估范围与依据	第一章
残余风险与整改	第九章、第十章
自评结论	第十一章